

SIMATS ENGINEERING

ASSESSMENT TOOL 3

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response
COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact. (BL2, BL3)*

Activity Tool : SIEM Alert Correlation and Incident Prioritization (Low)
Assessment Tool Weightage: 10%

Code of Conduct:

I _____shaikreehan192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
SIEM Alert Analysis and Correlation	25%	Thoroughly analyzes multiple SIEM alerts and accurately correlates events based on time, user, IP address, host, and activity patterns to establish a clear incident sequence.	Analyzes and correlates most relevant alerts with minor gaps in identifying relationships.	Performs basic alert analysis but correlation is incomplete or misses important relationships.	Unable to analyze or meaningfully correlate SIEM alerts.
Incident Verification and Security Event Analysis	20%	Effectively verifies the incident using SIEM logs, IDS/IPS, EDR, authentication data, IOCs, and threat intelligence, clearly distinguishing related and unrelated events.	Verifies the incident using relevant security data with minor omissions.	Performs limited verification using a small number of security sources.	Unable to verify the incident or analyze supporting security evidence.
Incident Classification and Prioritization	25%	Accurately classifies and prioritizes incidents based on severity, asset criticality, affected users, data sensitivity, business impact, and likelihood of further damage, with strong justification.	Correctly classifies and prioritizes incidents with reasonable justification and minor gaps.	Provides basic classification and prioritization but considers limited factors or provides weak justification.	Incorrectly classifies or prioritizes incidents with little or no justification.
Anomaly and Behavioural Analysis	15%	Effectively identifies abnormal patterns and behavioural deviations and uses them to support incident correlation, severity assessment, and prioritization.	Identifies major anomalies and behavioural deviations with minor gaps in analysis.	Identifies basic anomalies but provides limited behavioural analysis.	Unable to identify or interpret significant anomalies or behavioural patterns.
Documentation, Analysis, and Presentation	15%	Provides clear, professional documentation with incident timeline, alert correlation, evidence, prioritization rationale, conclusions, and appropriate diagrams or workflows.	Documentation is well organized and understandable with minor analytical or presentation issues.	Documentation is partially organized with limited evidence or unclear analysis.	Documentation is incomplete, poorly organized, and lacks supporting evidence or clear conclusions.

1. Threat Intelligence and SIEM Correlation

Introduction

Threat intelligence provides information about known or suspected malicious indicators such as **IP addresses, domains, URLs, file hashes, and malware infrastructure**. SIEM provides centralized visibility into events occurring inside the organization.

If a threat-intelligence feed identifies a malicious IP address and domain, and the SIEM detects an internal server communicating with those same indicators, the analyst should correlate, verify, classify, and prioritize the activity.

Step 1: Ingest the Threat Intelligence

The malicious indicators are first imported into the SIEM as threat-intelligence data.

For example:

Indicator	Threat Intelligence Finding
Malicious IP	Associated with active attack infrastructure
Malicious domain	Associated with malware/C2 activity
URL	Reported as malicious
File hash	Associated with known malware

The SIEM can then compare these indicators against existing security events.

Step 2: Search SIEM Events

The analyst searches historical and real-time logs for matches involving the malicious IP and domain.

Relevant sources include:

- Firewall logs
- DNS logs
- Proxy logs
- Network-flow data
- IDS/IPS alerts
- EDR telemetry
- Server logs
- Authentication logs
- Application logs

For example:

Threat Intelligence



Malicious IP + Domain



SIEM Indicator Matching



Internal Server Communication Detected



Investigate Source Host

Step 3: Correlate the Events

The analyst should correlate events using:

- **Timestamp**
- **Source IP**
- **Destination IP**
- **Hostname**
- **User/account**
- **Process**
- **Destination domain**
- **Port/protocol**
- **Connection frequency**
- **Amount of data transferred**

Example

Suppose the threat feed identifies:

Malicious IP → X.X.X.X

and

Malicious Domain → malicious-example.com

The SIEM detects:

10:20: Internal server resolves malicious-example.com



10:21: Server connects to the malicious IP



10:22: EDR identifies an unknown process initiating the connection



10:25: Large outbound traffic is observed

The correlation strongly suggests that the server may be communicating with malicious infrastructure.

Step 4: Identify IOCs

The investigation should extract additional IOCs.

Network IOCs

- Malicious source/destination IP
- Domain
- URL
- Destination port
- DNS request
- Network protocol

Host IOCs

- Suspicious process
- Process hash
- Executable path
- Command-line arguments
- New files
- Persistence mechanisms

Behavioural IOCs

- Repeated connections
- Periodic beaconing
- Unusual outbound traffic
- Communication at unusual times
- Unexpected external communication

The analyst should search these IOCs across the organization to determine whether other systems are affected.

Step 5: Verify the Incident

A threat-intelligence match alone does **not automatically prove compromise**.

The analyst should verify:

1. Did the server actually communicate with the malicious IP?
2. Was the communication initiated by a legitimate application?
3. Which process created the connection?
4. Did the server receive or send data?
5. Were files created or modified?
6. Did IDS/IPS detect malicious traffic?
7. Did EDR detect suspicious activity?
8. Is the domain/IP still classified as malicious?
9. Are other systems communicating with the same indicators?

If multiple independent sources confirm the activity, confidence in the incident becomes high.

Example Verification

Evidence Source	Finding
Threat intelligence	IP/domain reported malicious
DNS	Internal server queried malicious domain
Firewall	Connection to malicious IP
EDR	Unknown process initiated connection
Network monitoring	Repeated outbound communication
SIEM	Events occur within same time period

This provides strong evidence of a **true positive**.

Step 6: Classify and Prioritize

The incident can be classified as:

Incident Type: Malware infection / Command-and-Control communication

Priority depends on:

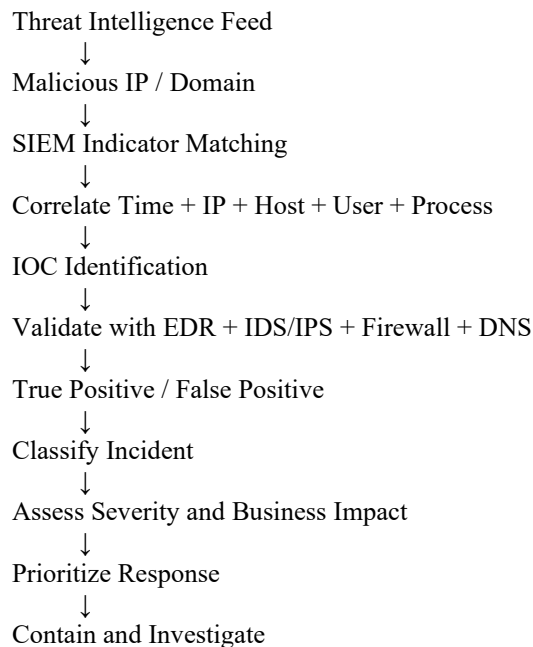
- Criticality of the affected server
- Sensitivity of the data
- Whether the server is production
- Whether credentials were compromised
- Whether malware is executing
- Amount of data transferred
- Number of affected systems
- Whether the attacker still has access
- Possibility of lateral movement

Example

If the affected server is a **critical financial database server** and it is actively communicating with known C2 infrastructure, the incident should be classified as **Critical priority**.

If the same indicator is found only in a blocked firewall connection with no successful communication, it may be **Medium or Low priority**, depending on context.

Incident Workflow



Conclusion

Threat intelligence becomes significantly more useful when correlated with SIEM telemetry. A match between a known malicious indicator and an internal server's activity should trigger investigation. By combining **SIEM, EDR, IDS/IPS, firewall, DNS, IOC analysis, and threat intelligence**, the analyst can verify the incident and determine its severity and priority.

2. Comprehensive SIEM Incident Analysis

Introduction

The financial organization's sequence of:

Multiple failed logins → unusual successful login → privilege escalation → suspicious process execution → large outbound data transfer

represents a potentially serious attack.

Because the organization is a financial institution, the possibility of **credential compromise, privilege abuse, malware infection, and sensitive-data exfiltration** makes this a potentially **Critical-severity incident**.

Step 1: Analyze and Correlate SIEM Alerts

First, collect all relevant events and arrange them chronologically.

Time	Event	Data Source	Significance
09:10	Multiple failed logins	Authentication	Possible credential attack
09:15	Successful unusual login	Authentication/VPN	Possible account compromise
09:18	Privilege escalation	Server/EDR	Possible attacker gaining higher privileges
09:20	Suspicious process execution	EDR	Possible malware/execution
09:25	Large outbound transfer	Firewall/Network	Possible data exfiltration

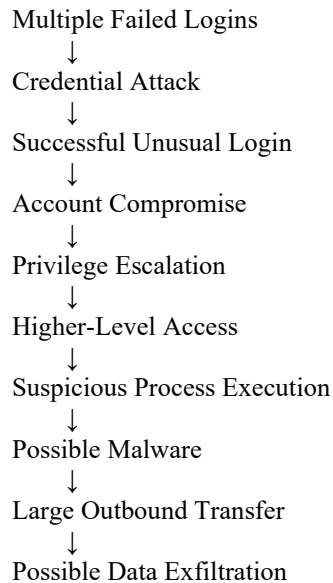
The analyst should correlate these events using:

- User/account
- Source IP
- Destination IP
- Hostname
- Timestamp
- Process
- Session ID
- Destination domain
- Network connection

If the same account and host appear throughout the sequence, the correlation becomes significantly stronger.

Step 2: Establish the Attack Sequence

The events may represent the following attack chain:



This is much more suspicious than treating each SIEM alert independently.

Step 3: IOC Identification

The analyst should extract IOCs from every stage.

Authentication IOCs

- Username
- Source IP
- Login time
- Unusual location
- Unusual device
- Failed-login frequency

Host IOCs

- Suspicious process
- Process hash
- Executable path
- Parent process
- Command-line arguments
- Modified files
- Persistence mechanisms

Network IOCs

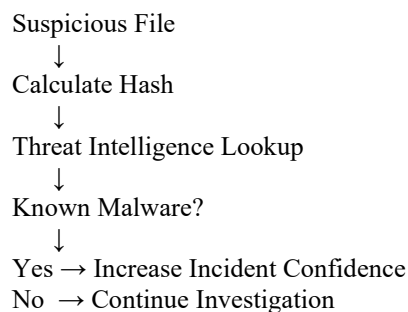
- Destination IP
- Domain
- URL
- Destination port
- Protocol
- Data-transfer volume
- Connection frequency

The identified IOCs should be searched across the entire organization.

Step 4: Threat Intelligence Analysis

The identified IP addresses, domains, URLs, and file hashes should be checked against threat-intelligence sources.

For example:



Similarly, suspicious external IP addresses and domains should be checked for associations with:

- Malware
- Command-and-control infrastructure
- Phishing
- Botnets
- Previous attacks

A lack of threat-intelligence matches does **not** automatically mean that the indicator is legitimate.

Step 5: Anomaly and Behavioural Analysis

The analyst should compare the observed activity against the user's and server's normal baseline.

Authentication anomaly

The user normally logs in from one location but suddenly logs in from an unusual location.

Privilege anomaly

A normal user suddenly obtains administrative privileges.

Process anomaly

A server launches an executable that it normally does not run.

Network anomaly

The server suddenly transfers a very large amount of data externally.

These deviations increase the likelihood that the account or system has been compromised.

Step 6: Use Multiple Security Sources for Verification

A Level-4 investigation should not rely on SIEM alone.

Authentication logs

Verify:

- Login history
- Source IP
- Account activity
- Privilege changes

EDR

Verify:

- Suspicious process
- File hash
- Parent process
- Command line
- Network connection
- Persistence

IDS/IPS

Check for:

- Exploit attempts
- Malware signatures
- Suspicious connections
- C2 traffic

Firewall

Determine:

- Destination IP
- Port
- Connection status
- Amount of traffic

Network monitoring

Analyze:

- Traffic volume
- Data-transfer pattern
- Destination
- Protocol
- Connection frequency

Application/database logs

Determine whether sensitive financial information was accessed.

Step 7: Incident Verification

The analyst must determine whether this is a **true positive** or **false positive**.

Questions to verify

- Was the login legitimate?
- Was the user actually at the unusual location?
- Did the user authorize the privilege escalation?
- Is the process legitimate?
- Was the outbound data transfer expected?
- Was the external destination approved?
- Was sensitive financial data accessed?
- Do EDR/IDS/IPS logs support the SIEM alerts?

If the user denies the login, the process is malicious, and the destination is associated with known attack infrastructure, the evidence strongly supports a true incident.

Step 8: Incident Classification

The incident could be classified as:

Primary classification: Account compromise / unauthorized access

Additional classifications:

- Privilege escalation
- Malware infection
- Command-and-control communication
- Possible data exfiltration

The final classification should reflect the most serious confirmed activity.

Step 9: Incident Prioritization

Because this is a **financial organization**, the incident should receive high priority.

Factors affecting priority

Factor	Assessment
Asset criticality	Potentially critical
User privilege	Elevated
Data sensitivity	High
Authentication compromise	Likely
Malware execution	Possible/likely
Data exfiltration	Suspected
Business impact	Potentially severe
Further damage	High possibility

Priority

Recommended Priority: P1 / Critical, if unauthorized access and sensitive-data exfiltration are confirmed or strongly indicated.

If investigation shows that the login and data transfer were legitimate, the alert priority should be reduced accordingly.

Step 10: Impact Assessment

The analyst should determine:

Confidentiality

Was sensitive financial/customer information accessed or transferred?

Integrity

Were financial records or system configurations modified?

Availability

Could the attacker disrupt critical financial services?

Scope

How many:

- Users?
- Servers?
- Endpoints?
- Applications?
- Databases?

were affected?

Business Impact

Potential consequences include:

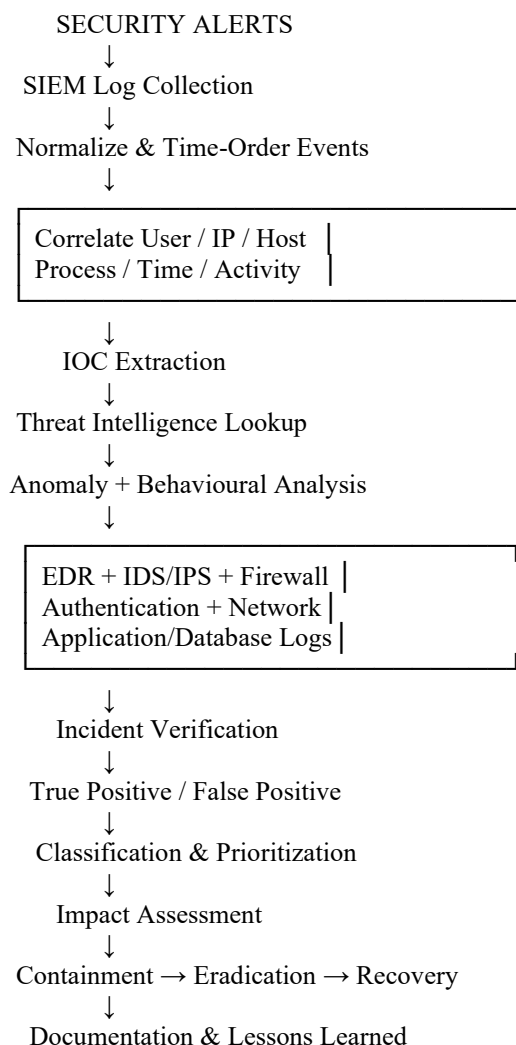
- Financial loss
- Customer-data exposure
- Regulatory consequences
- Reputation damage
- Service disruption
- Recovery costs

Step 11: Response and Containment

Once sufficient evidence confirms compromise, the security team should:

1. Isolate the affected endpoint/server.
 2. Disable or restrict the compromised account.
 3. Terminate malicious processes.
 4. Block malicious IP addresses/domains.
 5. Preserve forensic evidence.
 6. Search for the identified IOCs throughout the environment.
 7. Investigate lateral movement.
 8. Determine whether sensitive data was accessed.
 9. Remove malware and persistence.
 10. Reset compromised credentials.
 11. Monitor systems for recurrence.
 12. Document the incident and lessons learned.
-

Complete SIEM Incident-Analysis Workflow



conclusion

Credential Attack → Account Compromise → Privilege Escalation → Malicious Execution → Data Exfiltration

However, the analyst should **not declare the incident solely from the sequence**. Each stage must be verified using independent evidence from **SIEM, authentication logs, EDR, IDS/IPS, firewall, network monitoring, application/database logs, and threat intelligence**. For a financial organization, confirmed unauthorized access combined with privilege escalation and large outbound transfers should normally be treated as a **Critical/P1 incident**, because of the high sensitivity of financial and customer data and the potential for regulatory, financial, and reputational damage.